



LAB: FILE PATH TRAVERSAL, TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

Programacion Wap

Prof: Servando Lopez Contreras

David Campos Morado - 183511
Ingenieria en Tecnologias de la Información

Objetivo del Laboratorio

El objetivo de esta práctica es identificar y explotar una vulnerabilidad de File Path Traversal en una aplicación web que implementa una defensa incompleta. Se busca evadir el filtro que bloquea las secuencias de navegación relativa (como ../) utilizando una técnica de Absolute Path Bypass para lograr leer el archivo /etc/passwd del servidor.

Marco Teórico

File Path Traversal:

Es una vulnerabilidad que permite a un atacante leer archivos del servidor al manipular las rutas de acceso construidas a partir de la entrada del usuario sin la validación adecuada.

Absolute Path Bypass:

Muchas aplicaciones intentan defenderse filtrando secuencias como ../ (listas negras). Sin embargo, si el código pasa el parámetro a una API de lectura de archivos sin verificar si la ruta es absoluta, el atacante puede referenciar el archivo objetivo directamente desde la raíz del sistema (ej. /etc/passwd), ignorando el directorio base y evadiendo el filtro.

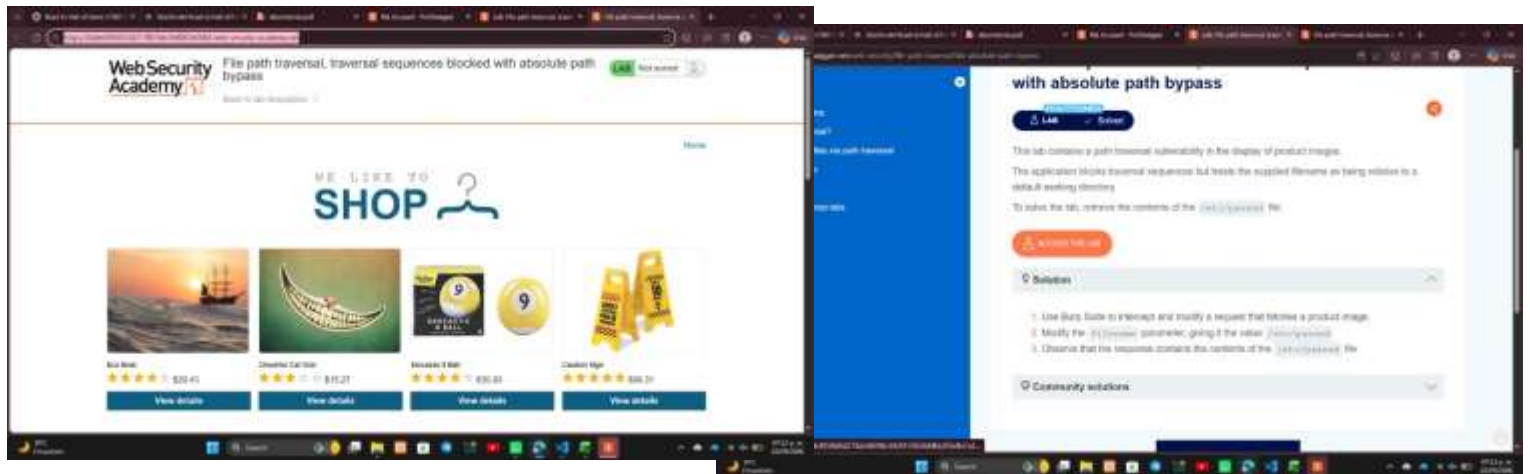
Entorno de Laboratorio

- Herramienta: Burp Suite Community Edition (Proxy, HTTP History, Repeater).
- Objetivo: Laboratorio instanciado en PortSwigger - Web Security Academy.

Desarrollo de la Práctica (Procedimiento y Evidencias)

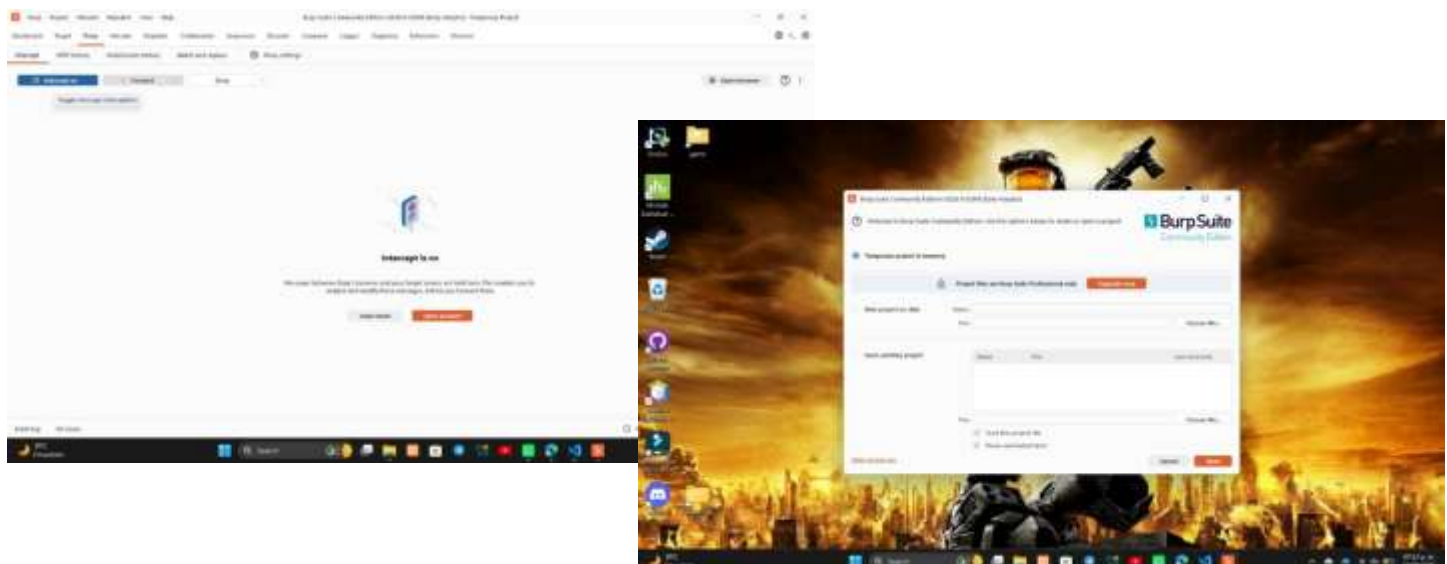
Paso 1: Análisis del entorno y objetivo

Se ingresó a la plataforma de PortSwigger para revisar las instrucciones del laboratorio, el cual indica que las secuencias de salto de directorio están bloqueadas y pide recuperar el contenido del archivo `/etc/passwd`. Posteriormente, se accedió a la tienda en línea vulnerable.



Paso 2: Preparación del entorno con Burp Suite

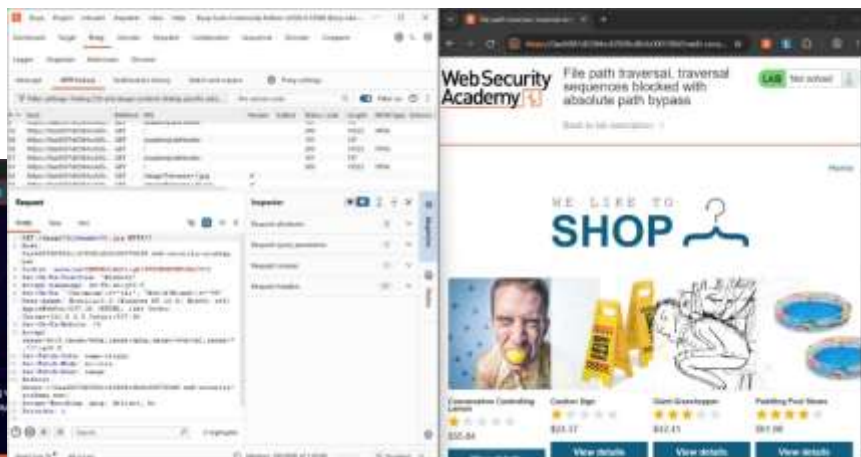
Para interceptar el tráfico, se inició Burp Suite Community Edition configurando un proyecto temporal en memoria con los ajustes predeterminados. Se activó el proxy (Intercept is on) y se abrió el navegador integrado de Burp para comenzar a capturar las peticiones de la tienda en línea.



Paso 3: Intercepción y análisis del tráfico HTTP

Al navegar por la tienda, se analizó el historial HTTP (HTTP history) en Burp Suite. Se identificaron las peticiones GET encargadas de cargar las imágenes de los productos. En estas peticiones se observó el parámetro filename que indica el recurso a solicitar (por ejemplo, 31.jpg o 75.jpg). Estas peticiones se enviaron al módulo *Repeater* para su manipulación.

```
Request
Pretty Raw Hex
1 GET /image?filename=75.jpg HTTP/2
2 Host: Gaa5007d0384cc47808cd0dc000700d5.web-security-academy.net
3 Cookie: session=G0H0Fn0ddflgkxJVZG0ISHCHUJKA2CCf
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; AppleWebKit/537.36 (KHTML, like Gecko; Chrome/151.0.0.0 Safari/537.36)
8 Sec-Ch-Ua-Mobile: 10
9 Accept: image/svg+xml,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer: https://Gaa5007d0384cc47808cd0dc000700d5.web-security-academy.net/
14 Accept-Encoding: gzip, deflate, br
15 Priority: 4
16
```



Paso 4: Comprobación del filtro de seguridad (Lista negra)

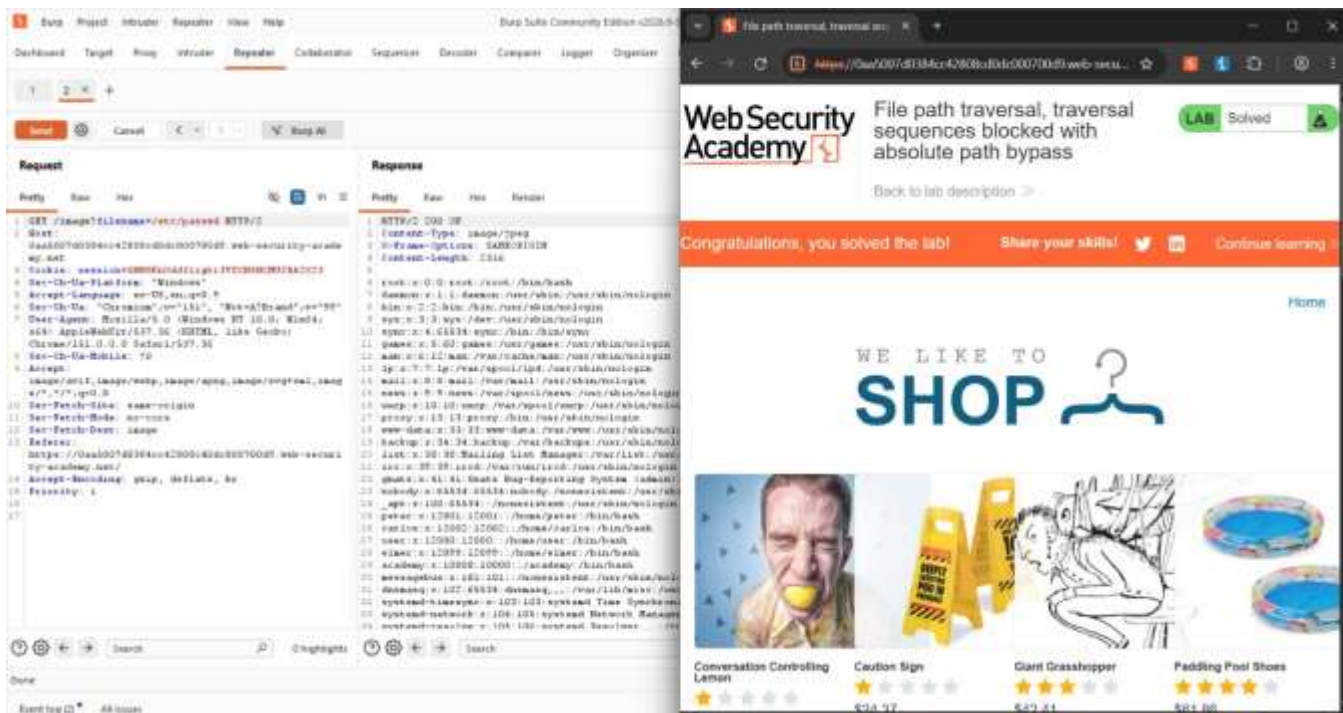
Para comprobar la protección descrita en las instrucciones, se intentó realizar un ataque clásico de Path Traversal utilizando rutas relativas. Se inyectó el payload `../../../../etc/passwd` en el parámetro filename. La respuesta del servidor fue un error 400 Bad Request indicando "No such file", lo que confirma que la aplicación bloquea correctamente las secuencias de punto-punto-barra (`../`).

```
Request
Pretty Raw Hex
1 GET /image?filename=../../../../etc/passwd HTTP/2
2 Host: Gaa5007d0384cc47808cd0dc000700d5.web-security-academy.net
3 Cookie: session=G0H0Fn0ddflgkxJVZG0ISHCHUJKA2CCf
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; AppleWebKit/537.36)

Response
Pretty Raw Hex Render
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 14
5
6 {"No such file"}
```

Paso 5: Explotación exitosa mediante Absolute Path Bypass

Dado que las rutas relativas están filtradas, se procedió a intentar un salto directo utilizando una ruta absoluta, omitiendo por completo los retrocesos de directorio. Se modificó el parámetro a filename=/etc/passwd. El servidor no validó si la entrada era una ruta absoluta y la procesó desde la raíz del sistema operativo. La respuesta fue un HTTP/2 200 OK devolviendo en texto plano la lista de usuarios del sistema. Con esta acción, el laboratorio quedó marcado como resuelto de manera exitosa.



Conclusión

La resolución de este laboratorio demuestra que implementar filtros de seguridad basados únicamente en listas negras (como bloquear la cadena ../) proporciona una falsa sensación de protección. Aunque la aplicación intentó proteger sus recursos bloqueando los retrocesos relativos, la falta de validación sobre rutas absolutas permitió extraer información confidencial del sistema operativo. Para mitigar esta vulnerabilidad de forma efectiva, es necesario implementar validaciones mediante listas blancas (permitiendo solo caracteres alfanuméricos y extensiones específicas como .jpg o .png) y verificar a nivel de código que la ruta canónica final del archivo no escape del directorio asignado para la aplicación.